Coveresy Insurance Operations Portal – Fresh Build Developer Note

Client: Coveresy Insurtech Private Limited **Owner / Approver:** Anwar (Founder & CEO) **Live portal:** https://coveresy-ops.higgsfield.app **Type:** Internal insurance operations, Policy MIS, document management and payout tracking system **Version:** 1.0 | **Date:** 12 October 2026

Important: the old portal at the link above is not working. Treat this as a **brand new build**. Do not try to repair the old code; reuse only the ideas. Everything the developer needs is in this note. Where a business answer is still pending, section 18 gives a default to build with, kept configurable so it can be changed later without code changes.

1. Objective

Build a new internal web portal for Coveresy's operations team to manage Health and Life insurance applications, policy records, mandatory document attachments, insurer/broker/partner details, employee-wise business, payout calculations, MIS reports and status tracking.

Non-negotiable principle: every dashboard number, report and status must come from real database records. No hardcoded demo data in production.

Users: Admin, Operator and Viewer (section 12). All access control is enforced on the server.

2. Tech Stack (new build)

Recommended stack (the developer may propose an alternative in writing before starting):

- Frontend: React + TypeScript, Vite, TanStack Start (or TanStack Router), a table library for sortable/paginated grids
- Backend: Cloudflare Workers with typed API routes and Zod validation on every input
- Database: Cloudflare D1 with versioned SQL migrations (Drizzle ORM or plain SQL)
- File storage: Cloudflare R2, private bucket only
- Passwords: salted slow hash (Argon2id or scrypt/PBKDF2 with a high work factor); sessions as opaque random tokens stored hashed in D1

- Money: store as integer paise, never floating point
- Hosting: Anwar's own Cloudflare account, so Coveresy owns the code repository, database and files. Repository on Coveresy's own GitHub organisation.

First task: set up the empty project, D1, R2 and secrets, deploy a login page to a staging URL, then share it for a quick check before building further.

3. Critical Business Rule: Mandatory Documents

These rules are fixed business requirements. They must not be changed without client approval.

Document	Health Insurance	Life Insurance
Policy Copy	**Mandatory**	Optional
Proposal Form	**Mandatory**	**Mandatory**
Payment Receipt	**Mandatory**	**Mandatory**

Behaviour:

- A Health application cannot be marked *Documents Complete* or *Verified* until all three documents are uploaded and pass verification.
- A Life application can proceed without a Policy Copy, provided the Proposal Form and Payment Receipt are uploaded and pass verification.
- An optional document must never block completion just because it is absent.
- A Rejected document never counts as verified.
- Switching an application from Life to Health must immediately trigger Health validation. Existing attachments must never be silently deleted on category change.
- Rules are stored as configurable Document Rules (editable by Admin only). The table above is the default seed data.

Enforcement must be both frontend and backend. Backend validation must apply to manual entry, edits, direct API calls and bulk imports. A file name or URL typed into a field is not proof of an uploaded file.

4. Authentication and Sessions (Priority 1)

The old portal failed with `Admin setup required: configure COVERESY_SESSION_SECRET`. The new build must handle secrets correctly from day one and show a clear setup screen only when a secret is genuinely missing.

Required actions:

1. Configure `COVERESY_SESSION_SECRET` as a server-side secret: at least 32 characters, cryptographically random.
2. Configure a separate `COVERESY_SETUP_TOKEN` for first administrator registration.
3. Never expose either value in client code, API responses, logs or source control.
4. Verify session creation, login, logout, expiry and secure cookie settings (HttpOnly, Secure, SameSite).
5. Protect initial admin setup with the setup token.
6. No default admin password. No authentication bypass.
7. Document how to rotate or disable the setup token after setup.
8. Test authentication on the deployed environment, not only locally.

5. Product Categories

Two categories: **Health Insurance** and **Life Insurance**. Every application must have one clearly identified category. Document requirements, status rules and reporting depend on it.

6. Documents and Attachments

6.1 UI (on Add/Edit Application and Application Detail pages)

For each document show:

- Document name and a Mandatory/Optional label
- Upload button
- File name, type, size
- Upload date/time and uploaded-by
- Verification status
- View/download, Replace and Remove actions (permission-controlled)

- Missing indicator
- Verification notes or rejection reason

Document statuses: Missing, Uploaded, Pending Verification, Verified, Rejected.

Show a completion summary, calculated dynamically from category and rules, for example: `2 of 3 required documents uploaded`. Uploaded-but-unverified documents must be shown separately from missing ones. Clearly list which documents are missing before the user can proceed.

6.2 Secure Storage

- Use private storage (Cloudflare R2 preferred). Never store file binaries in D1; store metadata and a storage reference only.
- No public or permanent URLs. Authorise every view/download on the server, using short-lived signed links or an authenticated download endpoint.
- Allow PDF, JPG, JPEG, PNG. Validate type, size and actual file content. Reject anything else.
- Generate safe storage keys; never trust user-supplied file names.
- Configurable file-size limit, documented in the deployment guide.
- Do not log personal information or document contents.
- Replacing a file must keep an audit record of the change.
- Provide a documented backup, retention and deletion process.

7. Policy MIS: Required Fields

All fields must be validated, searchable and filterable where sensible.

Application and policy: Internal Record ID, Insurance Category, Product/Plan Name, Login Date, Application Number, Policy Number, Customer Name, Premium Amount, Policy Status, Policy Issued Date, Policy Term, Premium Payment Frequency.

Insurer and distribution: Insurer, Insurer Representative Name, Broker Name, Partner Name, Partner Code, Employee Name, Assigned Operations User.

Payout: Gross Partner Payout, Payout Percentage, TDS Percentage, TDS Amount, Final/Net Payout, Payout Status, Payout Date, Transaction Reference/UTR.

Documents: Policy Copy Status, Proposal Form Status, Payment Receipt Status, Mandatory Documents Completion Status, Overall Document Verification Status, Last Document Updated At, Last Document Updated By.

Document status fields come from the document management system, not from spreadsheet text columns.

8. Workflow and Statuses

Application/policy statuses: Draft, Application Logged, Documents Pending, Documents Uploaded, Pending Verification, Verified, Submitted to Insurer, Policy Issued, Rejected, Cancelled.

Payout statuses: Not Eligible / Not Initiated, Pending, Approved, Processing, Paid, On Hold, Reversed.

Rules:

- Define permitted transitions and which role can perform each. (Developer to propose a transition matrix for client sign-off.)
- Document verification and policy issuance are separate states. Uploading documents never implies a policy is issued.
- Keep a timestamped history of status changes with the responsible user.

9. Payout Management

Required capabilities: partner-wise payout records; employee-wise and insurer-wise summaries; gross payout, payout %, TDS %, TDS amount, net payout; approval status; payment date; UTR; remarks; full history and audit trail.

Configurable formulas:

- Gross Payout = Eligible Payout Base × Applicable Payout Percentage
- TDS Amount = Applicable TDS Base × Approved TDS Percentage
- Net Payout = Gross Payout − TDS Amount − Other Approved Deductions

Do not assume the base is always the premium or that TDS is always 2%. Rates and bases must be configurable. Use decimal-safe currency arithmetic and consistent storage (for example integer paise). Prevent duplicate payouts. Keep records of reversals and corrections.

10. Dashboard and Reports

All figures from actual records:

- Total applications; Health count; Life count
- Policies issued
- Awaiting verification; missing mandatory documents; rejected documents
- Pending with insurers
- Total premium; gross payout; TDS; net payout; pending vs paid payouts
- Insurer-wise, broker-wise, partner-wise, employee-wise performance
- Monthly login and issuance trends

Clearly separate drafts, issued policies, pending and cancelled records.

Filters: date range, category, insurer, broker, partner, employee, policy status, document status, payout status.

Export: CSV and XLSX, respecting role permissions and the active filters. Do not export sensitive data or documents unnecessarily.

11. Master Data (CRUD)

Insurers, Products/Plans, Brokers, Partners, Partner Codes, Employees/Operations Users, Payout Rules, Document Rules, and configurable statuses. Prevent duplicates and preserve referential integrity. Document Rules are editable by Admin only.

12. Roles and Permissions (server-side)

Capability	Admin	Operator	Viewer
Manage users and roles	Yes	No	No
Configure document and payout rules	Yes	No	No
Secrets / settings	Yes	No	No
View all records	Yes	Assigned/authorised	Permitted read-only
Create/edit applications	Yes	Yes (authorised)	No

Capability	Admin	Operator	Viewer
Upload/replace documents	Yes	Yes	No
Verify/reject documents	Yes	Per approved matrix	No
Approve payouts	Yes	No	No
Audit logs and exports	Yes	Limited	No

Enforce on every endpoint. Hiding a button in the UI is not security. Prevent insecure direct object references.

13. Audit Trail

Log: login/logout; application create/edit; status changes; document upload, replace, remove, verify, reject; payout calculation changes, approvals and payments; user/role changes; sensitive exports; imports.

Each entry: actor, action, record reference, timestamp, before/after values where useful. Never log passwords, tokens or secrets.

14. Database and Data Integrity

- Tables for applications/policies, categories/products, insurers, brokers, partners, employees/users, document metadata and storage references, verification history, payouts and payout history, audit logs, and configurable rules.
- Use foreign keys, indexes, unique constraints and transactions.
- Hash passwords securely; use validated server-side sessions.
- Do not overwrite production data during migration. Deliver a migration and backup/restore plan **before** any destructive change.

14.1 Tables and key columns

Table	Key columns
users	id, name, email (unique), password_hash, role (admin/operator/viewer), status, created_at
sessions	id (hashed token), user_id, expires_at, created_at

Table	Key columns
insurers, brokers, partners, employees	id, name (unique), code, status; partners also have partner_code (unique)
products	id, insurer_id, category (health/life), name
applications	id, category, product_id, login_date, application_no, policy_no, customer_name, premium_paise, status, issued_date, policy_term, premium_frequency, insurer_id, insurer_rep_name, broker_id, partner_id, employee_id, assigned_user_id, doc_overall_status, created_by, created_at, updated_at. Unique: insurer_id + application_no
document_rules	category, doc_type (policy_copy / proposal_form / payment_receipt), requirement (mandatory/optional). Unique: category + doc_type
application_documents	id, application_id, doc_type, status, storage_key, original_name, mime_type, size_bytes, sha256, version, is_current, uploaded_by, uploaded_at, verified_by, verified_at, notes
document_events	id, document_id, action (upload/replace/remove/verify/reject), actor, at, before/after
status_history	id, application_id, from_status, to_status, actor, at, remark
payout_rules	id, insurer_id, product_id, partner_id (optional), base_type, payout_bp, tds_bp, effective_from, effective_to
payouts	id, application_id, base_paise, gross_paise, tds_paise, deductions_paise, net_paise, status, paid_date, utr (unique when present), rule_snapshot, remarks
payout_events	id, payout_id, action, actor, at, before/after
audit_logs	id, actor, action, entity, entity_id, before/after, ip, at

Table	Key columns
imports, import_errors	file name, uploader, status, row counts, row-level errors
settings	key, value (file-size limit, TDS default, verifier roles)

14.2 API endpoints (all require a valid session unless stated)

Method and path	Who	Purpose
POST /auth/setup	needs setup token	Create first admin, once
POST /auth/login, /auth/logout	public / any	Session start and end
GET/POST/PATCH /applications	Admin, Operator (read: Viewer)	List with filters, create, edit
POST /applications/:id/documents	Admin, Operator	Upload (multipart)
GET /documents/:id/download	by permission	Authenticated or signed short-lived download
POST /documents/:id/verify, /reject	per verifier setting	Verification with notes
POST /applications/:id/transition	per matrix 14.3	Change status; server checks document rules
GET/POST /payouts, POST /payouts/:id/approve, /pay	Admin approves	Payout lifecycle
GET /dashboard, /reports	all roles	Database-driven metrics
GET /export	by permission	CSV and XLSX of the active filters
POST /imports/preview, /imports/commit	Admin, Operator	Import with row errors
CRUD /insurers /brokers /partners /employees /products /rules	Admin	Master data
GET /audit-logs	Admin	Audit trail

14.3 Status transition matrix (proposed; Anwar to approve)

From	To	Who	Condition
Draft	Application Logged	Operator, Admin	Required MIS fields filled
Application Logged	Documents Pending	System	Mandatory documents missing
Documents Pending	Documents Uploaded	System	All mandatory documents uploaded
Documents Uploaded	Pending Verification	System	Verification requested
Pending Verification	Verified	Verifier	All mandatory documents Verified, none Rejected
Verified	Submitted to Insurer	Operator, Admin	Verified status held
Submitted to Insurer	Policy Issued	Operator, Admin	Policy number and issued date entered
Any open status	Rejected / Cancelled	Admin	Reason required

The server blocks any transition whose condition fails, even if the request comes straight from the API.

15. Import and Export

- CSV/XLSX import for authorised users, with import preview and row-level errors.
- Validate required fields and types; detect duplicate application/policy numbers (uniqueness rules to be agreed).
- Provide a downloadable error report. Never silently drop rows.
- Import must not mark documents as uploaded. If bulk attachment import is needed, build a separate secure process.
- Log all imports in the audit log.

16. UI/UX

Required sections: Dashboard, Policy MIS, Add Application, Application Detail, Documents & Attachments, Document Verification Queue, Payout Management, Insurers, Brokers, Partners, Employees & Users, Reports & Exports, Audit Logs, Settings.

Requirements: searchable, sortable, paginated tables; filters; clear status badges; form validation; confirmation before destructive actions; loading, empty and error states; responsive for desktop, tablet and mobile; accessible labels and clear error messages. The mandatory vs optional distinction must be obvious at a glance.

17. Security and Privacy

- HTTPS and secure cookies; server-side input validation.
- Authentication, authorisation, rate limiting, CSRF/origin protection.
- No secrets in client bundles or source control.
- Private attachments only; restricted downloads.
- Backup, retention and access-revocation procedures.
- Dependency and deployment security review.
- Do not claim any compliance certification without a formal assessment.

18. Business Decisions: Defaults to Build With

Anwar has not yet confirmed these rules. Build with the default shown, store every value as configuration (not hardcoded), and flag it in the test report as pending approval.

#	Decision	Default to build with
1	Payout base	Premium amount; selectable per payout rule (premium or net premium)
2	TDS	Percentage stored in settings and per rule, applied on gross payout; default value to be confirmed by Anwar, not hardcoded
3	Other deductions	Optional amount field, default 0
4	Payout rule structure	Insurer + product + partner; most specific rule wins; date-effective

#	Decision	Default to build with
5	Duplicate check	Application number unique per insurer; policy number unique per insurer when present
6	Who verifies documents	Admin only; a setting lets Admin allow Operators
7	Status transitions	As in 14.3
8	File limit and retention	10 MB per file, configurable; no automatic deletion
9	Operator visibility	Operators see records assigned to or created by them; Admin sees all
10	Bulk document import	Not in version 1; spreadsheet import never marks documents uploaded

19. Execution Plan

Phase 1: Setup and authentication. Create the repository, Cloudflare D1/R2/Workers, migrations and secrets; build setup, login, logout, sessions and role guards; deploy to a staging URL.

Phase 2: Database and documents. Metadata schema, private storage, exact Health/Life rules, backend validation, verification flow.

Phase 3: Policy MIS and workflow. Application forms, all MIS fields, statuses and history, filters, search, exports.

Phase 4: Payouts and reporting. Approved formulas, payout history, database-driven dashboard, reconciliation between payouts and MIS.

Phase 5: Security and QA. Role permissions, authentication, file access, migrations, audit logs, acceptance tests.

Phase 6: Deployment and handover. Deploy, smoke-test the live site, deliver documentation and test report.

Please share a short progress note at the end of each phase.

20. Acceptance Tests

The project is not complete until these pass. Do not mark a test passed unless it was actually executed.

Authentication

- Admin setup works with the configured secrets.
- Login and logout work; unauthorised users are blocked from protected endpoints.
- Sessions expire; production cookies are secure.

Document rules

- Health without Policy Copy, Proposal Form or Payment Receipt cannot be completed or verified (three separate tests).
- Life without Policy Copy can proceed when the other two are valid.
- Life without Proposal Form or Payment Receipt cannot be completed or verified.
- A rejected mandatory document does not count as verified.
- Switching Life to Health triggers Health validation.
- Direct API calls cannot bypass the rules.
- Unauthorised users cannot view or download documents.
- Replacement and verification actions appear in the audit log.

Payouts and MIS

- Calculations match approved formulas and configured rates; rounding is tested.
- Dashboard figures match the database; filters and exports are consistent.
- Duplicate payout and unauthorised approval scenarios are tested.

General

- TypeScript checks pass; production build succeeds.
- Migrations run without data loss.
- CRUD, import/export and role permissions are tested.
- Responsive layouts and error states reviewed.
- Smoke tests run on the live environment.

21. Deliverables

1. Updated source code.
2. Database migrations and schema changes.
3. Completed document upload and verification workflow.
4. Health and Life validation rules.

5. Updated Policy MIS and dashboard.
6. Payout management and reports.
7. Role and permission configuration.
8. Secure storage configuration and access controls.
9. Environment variables and deployment instructions.
10. Administrator setup instructions.
11. Backup and recovery instructions.
12. Written test report (passed / failed / blocked) and known limitations.
13. Live deployment URL and verification status.

22. Ground Rules

- Inspect first, then build within the existing architecture.
- Do not bypass authentication, expose private attachments, or fabricate dashboard figures.
- Do not declare the project production-ready before acceptance tests are complete.
- If a requirement cannot be completed, report the blocker and the remaining work clearly instead of silently omitting it.

Final reminder: Health Insurance Policy Copy is mandatory. Life Insurance Policy Copy is optional. Proposal Form and Payment Receipt are mandatory for both. These rules must be enforced in the UI and on the server.